



CEUB

EDUCAÇÃO SUPERIOR

Fundamentos em S. I.
Prof. Henrique Evaristo

ceub.br



Segurança da Informação

Introdução

Breve Histórico da Segurança de Redes

As redes de computadores

- Interligam todas as regiões do mundo
- Diminuem distâncias físicas
- Permitem que pessoas interajam rapidamente entre si em qualquer parte do globo

Breve Histórico da Segurança de Redes

- Originalmente não havia interconexão
- Crescimento Exponencial da Internet
 - Problemas de Segurança
 - Perda de controle sobre a rede
 - Dados valioso em computadores conectados
 - Desafios crescentes em relação à Cibersegurança

Breve Histórico da Segurança de Redes

- Acesso à Internet acessível em todos os locais do planeta
 - Novos modos de interação
 - Smartphones
 - Redes governamentais conectadas
 - Ônus: Cibercrime

Ataques em tempo real

Kaspersky

<https://cybermap.kaspersky.com/pt>

SonicWall:

<https://attackmap.sonicwall.com/live-attack-map/>

Mapa de Ameaças Fortinet:

<https://threatmap.fortiguard.com/>

Mapa de Ameaças de botnets em tempo real elaborado empresa de Tecnologia Spamhaus:

<https://www.spamhaus.com/threat-map/>

A relevância da Cibersegurança ou Cybersecurity frequentes notícias a respeito de ameaças cibernéticas de larga escala e ciberataques como:

- Hackers explorando vulnerabilidade de grandes empresas
- Novas formas de softwares maliciosos ou malwares
- Influências estrangeiras em eleições nacionais
- Indisponibilidade de sistemas

Cibersegurança - Relevância

Dado esse cenário, as organizações devem continuamente ***adaptar suas capacidades*** para lidar contra atores maliciosos e preveni-los seus ataques.

A ***Cibersegurança deve ser priorizada em todos os domínios da sociedade e da economia*** para destravar o verdadeiro potencial da economia digital.

Cibersegurança - Relevância

*No mundo digital, **a informação é um ativo fundamental** para as empresas, pois com a utilização da informação de seus clientes as empresas podem criar oportunidades de negócios.*

Cibersegurança - Relevância

Cibersegurança **NÃO É APENAS UMA QUESTÃO TECNOLÓGICA**,
mas é um conjunto de sistemas:

- Tecnologia
- Pessoas
- Processos

Dado, informação e conhecimento

- **Dado**

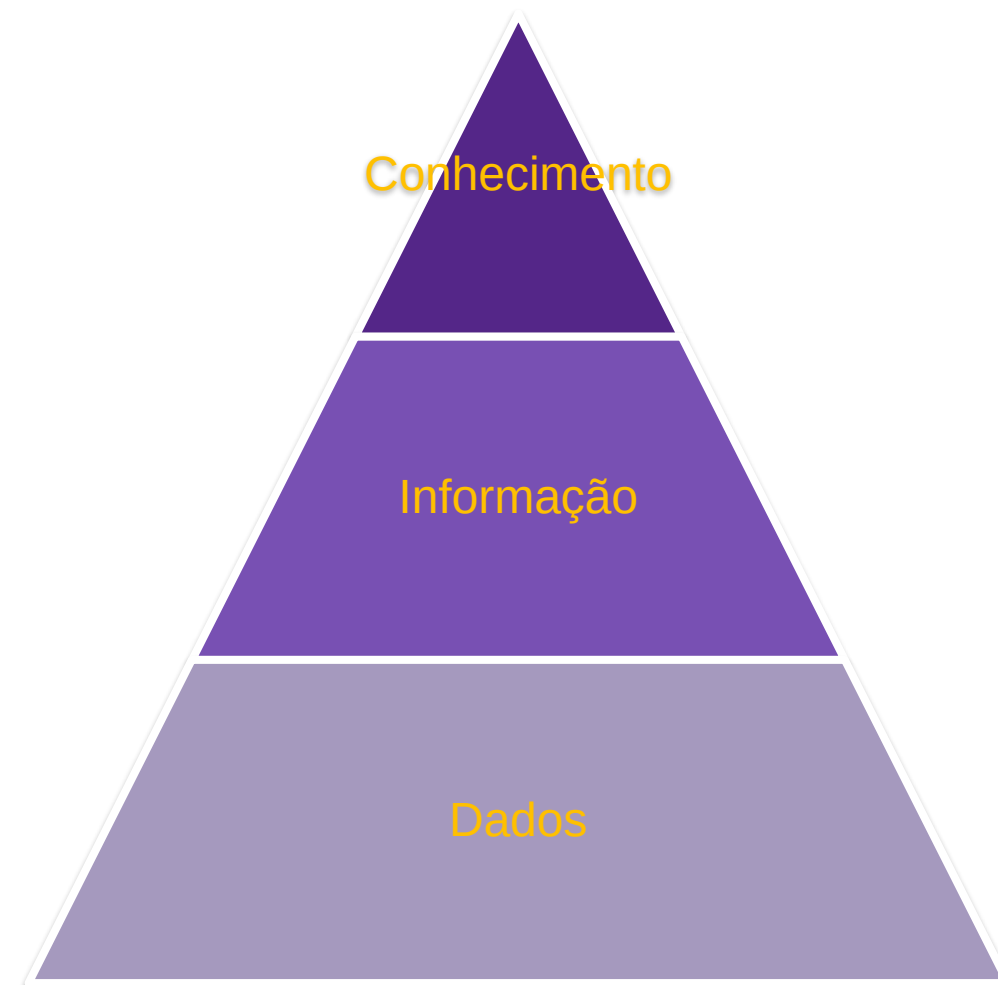
- *Observação do mundo externo*, pode representar o valor do lançamento de um dado, a idade de uma pessoa, o faturamento de uma empresa.

- **Informação**

- *Coleção de dados organizada e contextualizada*, esta passa a ter uma relevância, por exemplo, os últimos números da loteria, as idades de todos os alunos de uma sala, uma lista com os produtos mais vendidos ou maiores clientes de uma empresa

- **Conhecimento**

- *Junção de várias informações* sobre um mesmo tema, pode gerar conhecimento sobre o assunto. A informação pode estar presente em diversos componentes



Dado, informação e conhecimento

Elemento	Definição	Exemplo
Dados	Conjunto bruto de fatos e números, sem interpretação ou organização.	Temperatura registrada às 14:00: 30°C, 31°C, 29°C, 32°C.
Informação	Dados que foram processados, organizados ou apresentados de maneira a terem um significado.	A média da temperatura às 14:00 nas últimas quatro dias é 30.5°C.
Conhecimento	Informação assimilada e compreendida, podendo ser utilizada para tomada de decisão ou solução de problemas.	Sabendo que as temperaturas estão aumentando, recomenda-se ajustar o horário de irrigação das plantas para evitar a evaporação excessiva da água.

Informação

- Ativo muito valioso para a empresa
- Ativos para decisões, tratam entre outras coisas de:
 - Segredos industriais
 - Análise de mercado
 - Projeções e dados operacionais e financeiros
 - Históricos e pesquisas com consumidores

A junção de ***informações relevantes*** dos clientes de uma empresa possui muito ***valor*** para esta , já que com essas informações ela pode:

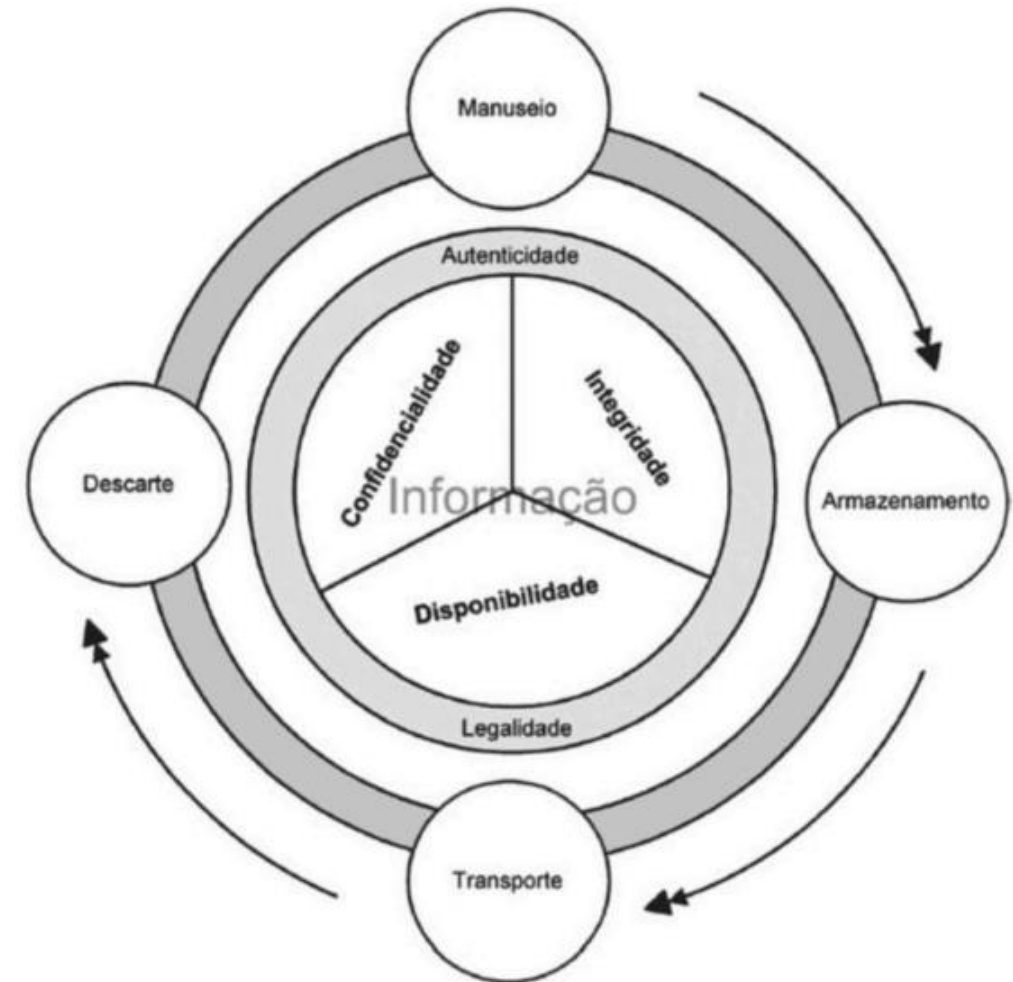
- Desenvolver novas formas de comunicação e de forma segmentada
- Acompanhar o ciclo de vida de um cliente
- Construir novos produtos adequados
 - Obter uma vantagem competitiva frente aos concorrentes que não possuem o histórico desse cliente

Concluindo, as *informações devem estar armazenadas de forma segura* , pois *vazamento de informações acarretam prejuízos financeiros e de imagem* para as empresas .

Nesse sentido , como qualquer outro ativo da empresa é *necessária e mandatória a proteção dos dados e das informações* contra os diversos tipos de ameaças

Ciclo de vida da informação

- Composto e identificado pelos **momentos vividos** pela informação que a colocam em risco
- Toda informação possui um prazo de validade determinado.
- Os momentos acontecem quando os ativos físicos , tecnológicos e humanos utilizam a informação , suportando processos que , por sua vez , mantêm a operação da empresa



Ciclo de vida da informação

1. Manuseio

A informação é criada e manipulada seja por folhear um maço de papéis , por digitar informações obtidas em uma aplicação Web ou por utilizar a senha de acesso para se autenticar no sistema .

2. Armazenamento

A informação será armazenada para eventual consulta futura e existem diversas formas de realizar esse armazenamento. É possível gravar as informações em um banco de dados compartilhado , em um arquivo na rede corporativo , no disco rígido , na nuvem ou em um pen-drive , guardado na gaveta.

3. Transporte

Ocorre de diversos meios . Podem ser através de uma mensagem de correio eletrônico , inserir informações em um sistema Web , apresentações em reuniões de trabalho ou ainda por conversas telefônicas com informações confidenciais .

4. Descarte

Existe um risco de depositar na lixeira da empresa materiais impressos , pois essas informações podem ficar disponíveis para concorrentes. Outra forma de eliminar informações é apagar arquivos do computador ou descartar discos rígidos com problemas

CIBERSEGURANÇA X SEGURANÇA DA INFORMAÇÃO

NIST(Instituto Nacional de Tecnologia e Padronização dos Estados Unidos)

"Segurança da Informação é a proteção da informação e dos sistemas de informação contra acessos não autorizados , usos , modificações , interrupções ou destruição com objetivo de prover confidencialidade , integridade e disponibilidade (1998)" .

A norma ISO / IEC 27032 : 2015 intitulada de Diretrizes para a segurança cibernética ou Guidelines for cybersecurity , define segurança cibernética ou cybersecurity :

"preservação da confidencialidade , da integridade e da disponibilidade da informação no espaço cibernético".

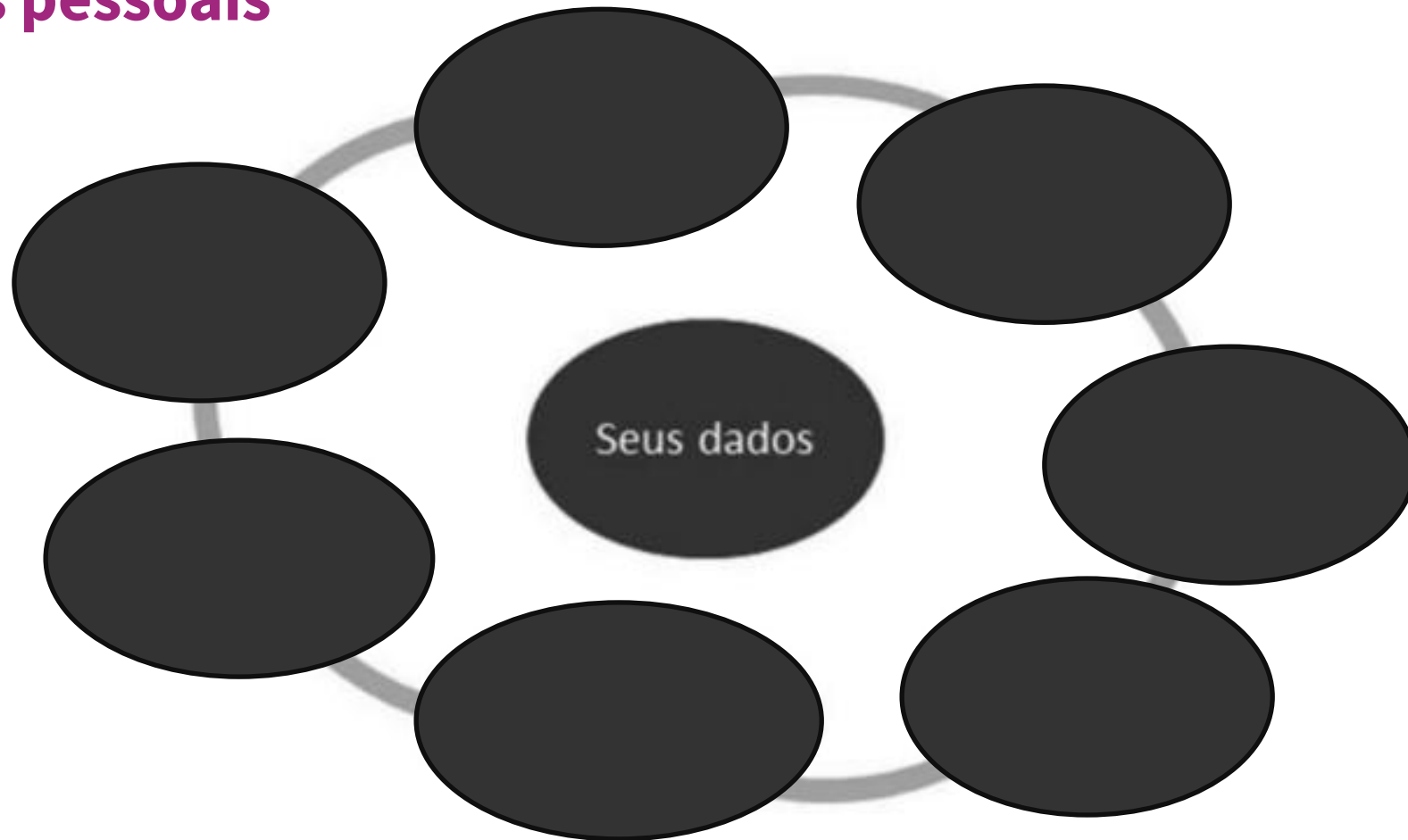
Segundo a CISCO (2020)

"a segurança cibernética é o esforço contínuo para proteger esses sistemas em rede e todos os dados de usos não autorizados ou prejudiciais"

Outro termo utilizado é Cibersegurança ou Cybersecurity , que representa o ***grupo de práticas que inclui atividades e controle ou medidas para atingir confidencialidade , integridade e disponibilidade dos dados e sistemas no ciberespaço*** contra ataques maliciosos que atingem desde organizações comerciais e governamentais e até dispositivos pessoais.

Essa proteção ocorre em diferentes esferas : empresarial , estatal e individual

Exemplo, dados pessoais



CIBERSEGURANÇA X SEGURANÇA DA INFORMAÇÃO

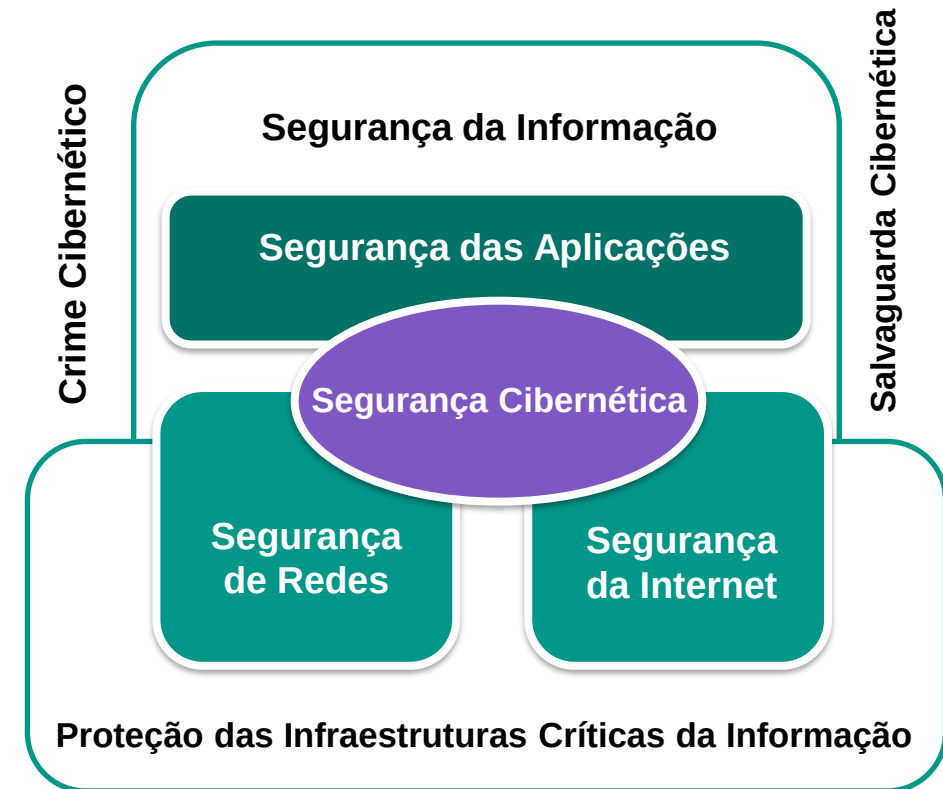
Apesar de muitas vezes serem utilizados como sinônimos , **existem diferenças entre cibersegurança e segurança da informação .**

A **diferença** entre cibersegurança e informação da segurança está nos **tipos de ativos que são protegidos .**

CIBERSEGURANÇA X SEGURANÇA DA INFORMAÇÃO

- **A Cibersegurança**
 - Verifica as **informações digitais** entre sistemas que estão conectados no ciberespaço
- **A Segurança da Informação**
 - **Não está restrita aos meios digitais**, mas também aos meios físicos como papel.

A figura a seguir ilustra os domínios da Segurança da Informação e da Segurança Cibernética



CIBERSEGURANÇA X SEGURANÇA DA INFORMAÇÃO

- Outra diferença é que os **profissionais de cibersegurança são treinados para lidar com especificamente as ameaças persistentes avançadas**, em inglês, Advanced Persistent Threats (APT).
- Por outro lado, **a segurança de informação está calcada na segurança dos dados** e os profissionais dessa área são treinados para priorizar os recursos antes de erradicar ameaças e ataques.
- Também é importante diferenciar os termos em inglês **Safety e Security**, pois a tradução literal para o Português de ambas as palavras é Segurança.
 - **Safety** está relacionada com a **integridade física ou verificação de risco de acidentes**.
 - Information Security ou **Segurança da Informação está ligada à proteção lógica dos dados** armazenados analisando disponibilidade, confidencialidade e integridade.
- Outro conceito importante é **Hacking**:
 - *“Campo da segurança computacional que se refere à exploração da vulnerabilidade de um sistema e comprometer os controles de segurança para ganhar acesso não autorizado e inapropriado. O hacking pode ser feito para roubar, furtar ou redistribuir propriedade intelectual, levando à perda financeira para empresas”(EC - COUNCIL, 2021).*

Termos e Conceitos

Existem diversas entidades que definem ou tentam padronizar alguns termos usado em SI, vejamos alguns, segundo a recomendação Segurança de arquitetura OSI , X.800 da **ITU-T** , pode - se definir os seguintes termos:

- **Ataques à segurança**
 - *Ações que comprometam a segurança* de informação pertencente a uma organização.
- **Serviço de segurança**
 - Trata-se da *realização de um processamento ou comunicação a fim de elevar a segurança* dos sistemas de processamento de dados e envios de informação de uma organização . Os serviços são utilizados para frustrar ataques à segurança e podem utilizar um ou mais mecanismos de segurança para prover o serviço
- **Mecanismo de segurança**
 - É um *processo ou um dispositivo incorporado a um processo o qual é projetado visando à detecção , ao impedimento ou à recuperação de um ataque* à segurança.

Termos e Conceitos

Existem outros termos também utilizados , como *ameaças e ataques* . Documentos técnicos produzidos por entidades e organização que lidam com Internet são denominados Request for Comment (RFC), "Pedidos de comentários" , em português.

De acordo com as **RFCs 2828 e 4949** , Glossários de segurança na Internet:

- **Ameaça**

- Algo que representa um potencial para a segurança ser violada no caso da ocorrência de um evento , ação ou circunstância , gerando danos . Dessa forma, uma ameaça é um provável perigo que pode explorar uma vulnerabilidade do usuário .

- **Vulnerabilidade**

- É uma condição, quando se explorada pelo atacante pode resultar em uma violação de segurança .

Termos e Conceitos

- **Vulnerabilidade (Segundo a Common Vulnerabilities and Exposures (CVE))**
 - Fraqueza que uma lógica computacional, por exemplo, o código, encontrado nos componentes de software e hardware que, quando explorada, pode resultar em um impacto negativo contra a confidencialidade, integridade ou disponibilidade.
- **A Mitigação de vulnerabilidades**
 - Envolve alterações na codificação , mas pode também incluir alterações de especificações ou até mesmo depreciações nas especificações , por exemplo , a retirada e protocolos afetados . (CVE, 2022) .
- **Exposição**
 - Configuração incorreta do sistema ou erro no software que permite acesso a informações ou capacidade que pode ser utilizado por um hacker como um trampolim para o sistema ou rede .

Termos e Conceitos

- **Incidente de segurança**

- Pode ser definido como qualquer evento adverso, seja este confirmado ou sob suspeita , relacionado à segurança de sistemas computacionais ou de redes de computadores.

- **São exemplos de incidentes de segurança**

- Tentativas , com sucesso e sem sucesso , de obter acesso não autorizado para um sistema ;
- Utilização ou acesso não autorizado a um sistema ;
- Interrupção indesejada de serviço por ataques de negação de serviço ;
- Modificações em um sistema , sem o conhecimento, instruções ou consentimento prévio do responsável do sistema ;
- Desrespeito à política de segurança ou ao uso aceitável de uma empresa ou provedor de acesso.

Termos e Conceitos

- A Organização Internacional de Padronização ou **International Organization for Standardization (ISO)** criou uma família de normas voltadas para gestão e operação da Segurança da Informação, **ISO 27000** e suas variantes. A existência reflete o amadurecimento da área da área de segurança e impõe novos desafios para área de segurança de informação.

De acordo com (ISO/IEC, 2007) Ativo é ***"Qualquer coisa que tenha valor para a organização"***.

- ***Exemplos de Ativos:***
 - Hardware
 - Software desenvolvido para a empresa
 - Marca comercial
 - Um segredo ou patente industrial

Termos e Conceitos

Esses conceitos de segurança de informação estão interligados da seguinte forma

"Uma **ameaça** explora uma **vulnerabilidade** presente em um **ativo** , que não é protegido por um **controle de segurança**"

(GONTIJO , 2022)

Obrigado

Prof. Henrique Evaristo



